

SOFTWARE REQUIREMENTS SPECIFICATION

Lightweight Threat Modeler Tool

Ethical Hacking & Application Security Course Project

Field	Details
Document Version	1.0 (Draft)
Prepared By	Student Team
Reviewed By	Prof.Vaishali Mishra & Mr.Ashish Kulkarni
Date	11 March 2026
Status	For Review & Presentation

1. Introduction

1.1 Purpose

This Software Requirements Specification (SRS) defines the functional and non-functional requirements for a Lightweight Threat Modeler Tool. This tool is designed to assist security analysts, developers, and application owners in performing structured threat modeling on both existing (legacy) and new (in-development) applications.

The document is intended for the course project team, the supervising cybersecurity lead, and academic evaluators.

1.2 Project Background

During a course mentoring session, the cybersecurity lead highlighted a significant industry gap: approximately 90-95% of applications currently in production have never undergone formal threat modeling. This gap exists because:

- Earlier practices did not emphasize threat modeling as a mandatory activity.

- Organizations perceived it as redundant or cost-prohibitive.
- Regulatory mandates (e.g., RBI guidelines for banks) have recently made threat modeling compulsory, creating backlog demand.

The mentor outlined that threat modeling is not merely an application-level tool — it is a methodology used during design, architecture, and ongoing maintenance phases. The project goal is to build a low-level, automation-assisted threat modeler grounded in industry-standard models.

1.3 Scope

The Low-Level Threat Modeler Tool will:

- Accept input describing an existing or new software application.
- Decompose the application into modules and data flows.
- Apply the STRIDE threat model to identify threats per component.
- Rank identified threats using the DREAD scoring model.
- Generate a structured threat report with Data Flow Diagrams (DFDs) and prioritized remediation recommendations.
- Support both legacy applications (already in production) and applications under active development.

Out of scope for v1.0: Cloud-specific or infrastructure threat modeling, integration with live CI/CD pipelines, active penetration testing execution.

1.4 Definitions and Acronyms

Term / Acronym	Definition
STRIDE	Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege — a threat classification model by Microsoft
DREAD	Damage, Reproducibility, Exploitability, Affected Users, Discoverability — a risk-ranking model
PASTA	Process for Attack Simulation and Threat Analysis — an industry-standard threat modeling framework
DFD	Data Flow Diagram — a visual representation of how data moves within and outside a system
SRS	Software Requirements Specification
Threat Modeling	A structured methodology to identify, classify, and prioritize threats to a system
Legacy Application	Software already deployed in production without prior threat modeling
APPSEC	Application Security

2. Overall System Description

2.1 Product Perspective

The tool operates as a standalone desktop or web-based application. It does not replace existing security tools (e.g., Burp Suite) but complements them by providing a structured, methodology-driven front-end for threat discovery before active testing begins. The output of this tool serves as direct input to penetration testing and application security review activities.

2.2 Product Functions (High-Level)

- Application intake & decomposition into modules/data flows
- STRIDE-based threat questionnaire and automated identification
- DREAD-based threat scoring and ranking
- DFD generation showing inter-component data flows
- Consolidated threat report generation
- Application prioritization for security testing schedules

2.3 User Classes and Characteristics

User Type	Description	Technical Level
Security Analyst	Conducts threat modeling sessions with development teams	High
Developer / Architect	Provides application design details during modeling	Medium-High
Application Owner	Reviews threat reports and approves remediation plans	Low-Medium
Course Evaluator	Assesses the tool for academic project review	Medium

2.4 Operating Environment

- Platform: Web-based (browser) or cross-platform desktop application
- Input Formats: Text description, JSON/YAML application schema, or manual form entry
- Output Formats: PDF/DOCX report, DFD image export, JSON threat data

2.5 Assumptions and Dependencies

- The user provides accurate application architecture descriptions.
- STRIDE and DREAD models are implemented as described in their standard specifications.
- DFD generation may rely on an open-source diagramming library (e.g., Mermaid, Graphviz).
- Regulatory context (e.g., RBI mandates) is considered informational and not enforced by the tool.

3. Functional Requirements

3.1 Application Input Module

FR-01: Application Profile Entry

- The system shall allow the user to input application metadata: name, type, deployment environment, technology stack, and brief functional description.
- The system shall support both new applications (under development) and legacy applications (already in production).

FR-02: Application Decomposition

- The system shall allow the user to decompose the application into functional modules (e.g., Login, Loan Application, Approval Workflow, MIS Reports).
- For each module, the user shall define: inputs, outputs, data stores accessed, and external entities interacting with it.
- The system shall support hierarchical decomposition (module > sub-module).

3.2 Data Flow Diagram (DFD) Module

FR-03: DFD Generation

- The system shall auto-generate a Level-0 (Context) and Level-1 DFD based on the application decomposition provided.
- DFDs shall visually distinguish: External Entities, Processes, Data Stores, and Data Flows.
- The system shall flag data flows that cross trust boundaries (e.g., HTTP vs HTTPS, internal vs external network).

FR-04: Trust Boundary Marking

- The user shall be able to manually annotate trust boundaries on the DFD.
- The system shall highlight all data flows crossing trust boundaries as high-priority items for STRIDE analysis.

3.3 STRIDE Threat Identification Module

FR-05: STRIDE Questionnaire

- For each DFD element (process, data store, data flow, external entity), the system shall present a structured STRIDE questionnaire.
- Questions shall be pre-mapped to the six STRIDE categories: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege.
- The user shall be able to mark each threat as: Applicable, Not Applicable, or Under Review.

FR-06: Automated Threat Suggestion

- Based on the technology stack and module types, the system shall suggest likely threats automatically (e.g., SQL Injection for database-connected modules, weak cipher alerts for data flows).
- Suggested threats shall be editable and confirmable by the analyst.

3.4 DREAD Scoring Module

FR-07: DREAD Risk Ranking

- For each identified threat, the system shall prompt the user to score it across five DREAD dimensions: Damage Potential, Reproducibility, Exploitability, Affected Users, Discoverability.
- Each dimension shall be scored 1-10. The system shall compute a composite DREAD score.
- Threats shall be ranked: Critical (>8), High (6-8), Medium (4-5), Low (<4).

FR-08: Risk Prioritization Dashboard

- The system shall display a prioritized list of threats sorted by DREAD score.
- The dashboard shall allow filtering by STRIDE category, module, and severity level.

3.5 Report Generation Module

FR-09: Threat Modeling Report

- The system shall generate a structured report containing: executive summary, application overview, DFD diagrams, threat list with STRIDE categories, DREAD scores and ranking, and recommended mitigations.
- Reports shall be exportable as PDF and DOCX.

FR-10: Application Prioritization Output

- The system shall generate an application prioritization matrix for organizations with multiple applications, combining business criticality (user-input) and DREAD-based threat proneness.
- Output shall recommend testing frequency (e.g., monthly, quarterly, annually).

4. Non-Functional Requirements

ID	Category	Requirement
NFR-01	Usability	Non-security users (application owners) shall be able to complete an application profile entry with guided prompts in under 30 minutes.
NFR-02	Performance	DFD generation shall complete within 5 seconds for applications with up to 20 modules.
NFR-03	Scalability	The tool shall support modeling of applications with up to 100 modules without performance degradation.
NFR-04	Security	All threat data entered shall be stored encrypted at rest. Access shall be role-restricted.
NFR-05	Portability	The tool shall run on Windows, macOS, and major Linux distributions, or via any modern web browser.

ID	Category	Requirement
NFR-06	Maintainability	STRIDE questionnaire templates shall be configurable via external JSON files, not hard-coded.
NFR-07	Compliance	The methodology implemented shall align with Microsoft Threat Modeling and OWASP threat modeling guidelines.

5. System Architecture Overview

5.1 High-Level Architecture

The tool follows a layered architecture:

1. Input Layer: Application profile and module decomposition forms
2. Processing Layer: STRIDE engine, DREAD scoring engine, DFD generator
3. Persistence Layer: Local or server-based storage for threat data and session state
4. Presentation Layer: Dashboard UI, DFD visualizer, report builder

5.2 Supported Threat Models

Model	Purpose	Implementation Priority
STRIDE	Threat identification and classification per component	Phase 1 (Core)
DREAD	Risk scoring and ranking of identified threats	Phase 1 (Core)
PASTA	Process-oriented attack simulation framework	Phase 2 (Future)
Cloud Threat Modeling	Infrastructure and cloud-specific threats	Phase 3 (Future)

5.3 Data Flow Overview

A typical tool interaction follows this sequence:

5. Analyst enters application profile and decomposes into modules.
6. System generates Level-0 and Level-1 DFDs with trust boundary annotations.
7. Analyst completes STRIDE questionnaire per DFD element.
8. System logs confirmed threats and prompts for DREAD scoring.
9. System computes DREAD scores, ranks threats, and populates the risk dashboard.
10. Analyst reviews, edits, and finalizes the threat list.
11. System generates the consolidated threat modeling report.

6. Key Use Cases

UC-01: Threat Model a Legacy Application

Actor: Security Analyst

Precondition: Application is already in production; no prior threat model exists.

Flow: Analyst enters application metadata → decomposes into modules → reviews auto-generated DFD → completes STRIDE questionnaire → DREAD-scores threats → exports PDF report.

Outcome: A structured threat model is created for an existing application, enabling prioritized remediation and future test planning.

UC-02: Threat Model During Design Phase

Actor: Security Analyst + Architect

Precondition: Application is in design/architecture phase.

Flow: Architect provides design specs → Analyst decomposes in tool → Threats identified early → Flagged in design documents → Development proceeds with threat-aware design.

Outcome: Threats are identified before code is written, reducing remediation cost.

UC-03: Prioritize Applications for Security Testing

Actor: Security Manager / CISO

Precondition: Organization has 50+ applications with no structured testing schedule.

Flow: Import application list → Assign business criticality → Run DREAD-based threat proneness for each → System generates prioritization matrix.

Outcome: Top 30% of applications identified for monthly/quarterly testing; remainder scheduled annually.

7. Open Questions & Items for Next Discussion

The following items were not fully resolved in the initial mentoring session and require clarification before finalizing the design:

#	Open Question	Owner
OQ-01	Should the tool support import of existing architecture diagrams (e.g., draw.io, Visio) to auto-populate DFDs?	Team + Mentor
OQ-02	What is the expected input format for legacy applications — text description, code scan output, or API schema?	Team

#	Open Question	Owner
OQ-03	Should PASTA be included as an alternative modeling path in Phase 1 or deferred to Phase 2?	Mentor
OQ-04	What is the preferred report format required by the course evaluators — PDF, web dashboard, or both?	Mentor / Evaluator
OQ-05	Should the tool store historical threat models to enable trend analysis across versions of the same application?	Team
OQ-06	Is integration with tools like Burp Suite or OWASP ZAP in scope for any phase?	Mentor
OQ-07	What user authentication model is required — single user local tool, or multi-user with role-based access?	Team

8. Document Revision History

Version	Date	Author	Changes
1.0	11 Mar 2026	Student Team	Initial draft based on mentoring session transcript

— End of Document —